

Controller-vs-Processor Determination - Memo for Counsel

Controller-vs-Processor Determination - Memo for Counsel

Status: unresolved (HUMAN_CONFIRMATION_NEEDED.md G14). This determination gates 01, 02, and 05 in this folder - resolve this first.

The question

Under PDPL, does Taweed act as controller or processor with respect to the clinic's patient/claims data (PHI) that flows through the product? And separately: for the sub-transfer of a subset of that data to Anthropic (US-based LLM vendor), what role does Taweed hold there?

Facts as currently understood (not a legal conclusion)

- Clinics are Taweed's customers. They own the underlying patient/insurance relationship and the NPHIES ClaimResponse data originates from their systems.
- Taweed's product ingests that data, runs it through denial-detection/appeal-drafting logic (some of it AI-assisted, some of it deterministic rule-matching), and returns analysis/output to the clinic. Taweed does not sell the data onward, does not use it to train models across clients, and processes it only to deliver the service the clinic contracted for.
- Taweed does independently decide *how* the data is processed technically (which AI provider, what's sent to it, what's retained, for how long) - this is the fact pattern that usually points toward "processor acting on the controller's instructions," but self-determined technical architecture can blur into controller-like decision-making depending on how much discretion Taweed exercises versus how much is dictated by the clinic contract.
- A subset of data (whatever's included in an AI-2 appeal-drafting or AI-4 EOB-extraction request) is sent to Anthropic's API, hosted in the US (inference_geo="us" per packages/ai/src/anthropic-1p.ts). Anthropic processes it transiently for inference and, per its own API terms, does not train on API inputs by default - but the cross-border transfer itself happens regardless of Anthropic's retention policy.

Why it matters (from G14)

- Controllers processing sensitive data or doing cross-border transfers must register on SDAIA's National Data Governance Platform.
- DPO appointment is mandatory for large-scale sensitive-data processing or cross-border transfers, with the DPO registered with SDAIA.
- On its face, Taweed's activity (sensitive health data + a US cross-border transfer) hits both triggers - but these duties attach to the controller. In the clinic-SaaS model the clinic is likely the controller with Taweed as processor, which would mean these specific duties land on the clinic, not Taweed - but that's exactly what needs a lawyer's actual determination, not an assumption.
- Proposed 2025 PDPL amendments that would consolidate/clarify these rules were still unpublished as of May 2026 - this is an evolving area, not a settled one.

[COUNSEL TO CONFIRM]

1. Is Taweed the controller, the processor, or (for different data flows) both, with respect to PHI ingested from clinics?
2. Does Taweed's independent choice of AI subprocessor (Anthropic) and its architecture decisions

change that determination, or does it stay "processor acting on documented instructions" as long as the clinic contract authorizes it?

3. Given the determination above, does SDAIA registration or DPO-appointment duty land on Taweed, on the clinic, on both, or on neither yet (pre-scale)?

4. Does the determination differ for the direct clinic<->Taweed relationship versus the Taweed<->Anthropic sub-transfer (i.e., could Taweed be "processor" to the clinic but hold a different role, such as "data exporter," for the Anthropic leg)?

Downstream effect

Whatever counsel determines here directly decides:

- Who signs which side of the SCC in 01-scc-controller-to-processor.md.
- Who owns and files the SDAIA risk assessment in 02-sdaia-risk-assessment.md.
- The role language throughout the DPA template in 05-dpa-template.md.